

Athena V1.0 Security Architecture Gap Assessment & Optimization Report

Read-only assessment of Athena v2.3 against the user-provided enterprise and financial-grade security architecture V1.0, with a prioritized optimization roadmap.

Athena v2.3 · Enterprise / Financial-grade Target Review · 2026-07-20

Classification: Internal Architecture & Security Review **Assessment mode:** authorized, local, read-only, non-destructive **Audience:** CTO, Architecture Committee, Security Committee, Product Infrastructure and Engineering Leadership

Technical Summary — 产品级安全基础成熟，但距离 V1.0 金融级完整运营模型仍有 39% 证据与控制缺口

结论：Athena 不需要推倒重写。 当前产品安全姿态维持 **7.4/10**；按用户提供的 V1.0 大型互联网/金融级完整目标重新衡量，加权完成度为 **61.0%**。两者不是矛盾：前者评价产品当前防护，后者还包含外部 WAF/DDoS、工作负载身份与 mTLS、HSM/KMS、DLP、SIEM/SOAR、JIT/PAM、独立安全账户和跨区域灾备等组织与基础设施能力。

Athena 的领先部分是：**业务权威、同步一致性、实时通知、内容对象和完整性证明彼此解耦**。Sync V2 的 version/hash/outbox/cursor 并不替代 WebSocket/SSE，Chat Hash Chain 不替代加密，NATS 也不成为业务数据库。当前 1,038 条 Chat prompt/response 全部加密且链断裂为 0；263 个 Sync 节点和 186 个投影没有 Hash、权限或正文冲突；338 个高风险路由静态审计为 0 finding。

本次仍确认 **4 个 High**：WebSocket 未统一执行权威 Session V2；Collector 开发入口接受 absolutePath；Collector 继承过宽 .env/存储挂载；workspace rag-memory 缺少 provenance/taint/候选审批。它们应先闭环，再推进 KMS、mTLS、SIEM 或多账户治理。

Source: Athena V1.0 security gap evidence snapshot

Tables: workspace_chats, sync_nodes

Product security posture

7.4

Current product security posture from the local architecture/security review; not a compliance certification.

Source: Athena V1.0 security gap evidence snapshot

Tables: workspace_chats, sync_nodes

V1.0 blueprint completion

61

Weighted completion against the broader financial-grade V1.0 target operating model.

Source: Athena V1.0 security gap evidence snapshot

Tables: workspace_chats, sync_nodes

Confirmed High findings

4

Confirmed High code-path findings requiring P0 ownership.

Source: Athena V1.0 security gap evidence snapshot

Tables: workspace_chats, sync_nodes

Route audit findings

0

Static high-risk route audit across 338 routes.

Source: Athena V1.0 security gap evidence snapshot

Tables: workspace_chats, sync_nodes

Sync projection conflicts

0

Hash, permission and projection conflicts in the read-only Sync V2 audit.

Source: Athena V1.0 security gap evidence snapshot

Tables: workspace_chats, sync_nodes

Invalid Chat chain

0

Invalid Chat Hash Chain entries across the audited 1,038-row corpus.

Source: Athena V1.0 security gap evidence snapshot

Tables: workspace_chats, sync_nodes

Verified Local Evidence

Short-form evidence table; detailed controls use wrapping audit tables below.

Source: Athena V1.0 security gap evidence snapshot

Tables: workspace_chats, sync_nodes

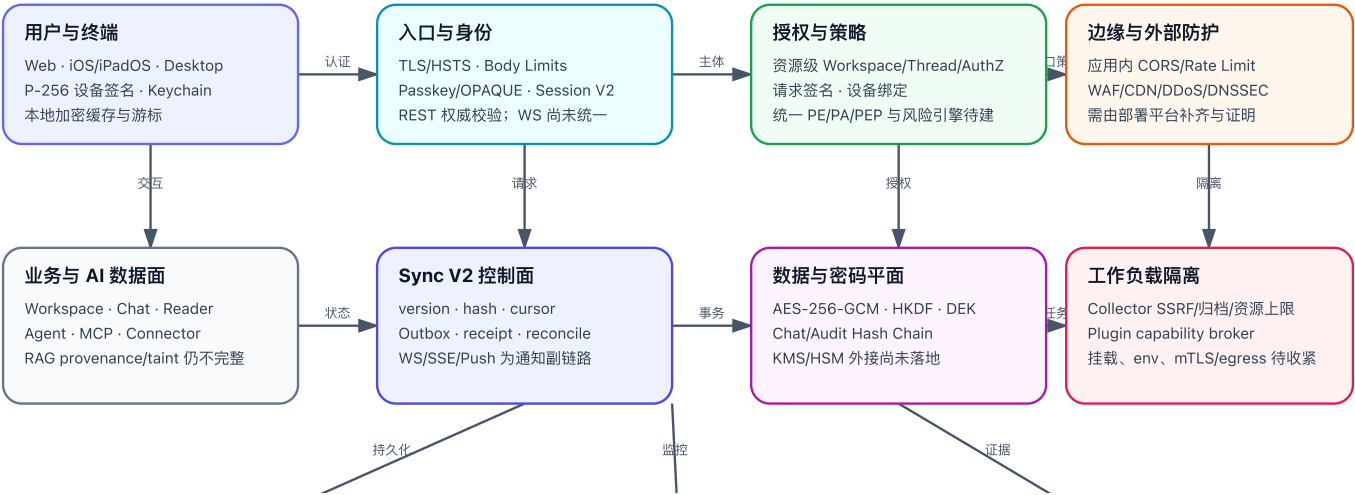
Check	Result
Auth DB	quick_check=ok; foreign_key=0
Chat crypto	1,038/1,038 encrypted; invalid chain=0
Main DB	quick_check=ok; foreign_key=0
Route audit	338 routes; findings=0
Supply chain	reachable Critical=0
Sync V2	263 nodes; 186 projections; conflicts=0

Evidence Contract — 不把代码适配、开发运行态和生产证明混为一谈

- 已验证实现：当前仓库、开发数据库、运行中的 Web/API/Collector、只读审计脚本和静态控制扫描。
- 适配/故障测试准备：PostgreSQL、NATS JetStream、S3/MinIO、OTel、Key Custody 外接边界；证明接口与失败语义，不证明生产容量或可用性。
- 外部控制不可见：CDN/WAF/DDoS/DNSSEC、云账户隔离、KMS/HSM、SIEM/SOAR、对象锁与跨区域灾备，需要部署平台证据。
- 评分尺度：0 缺失；1 设计/占位；2 部分实现；3 本地实现；4 强制+监控；5 独立证明+周期演练。

1. Current Architecture vs. V1.0 Target

Athena 当前安全架构与 V1.0 目标控制面



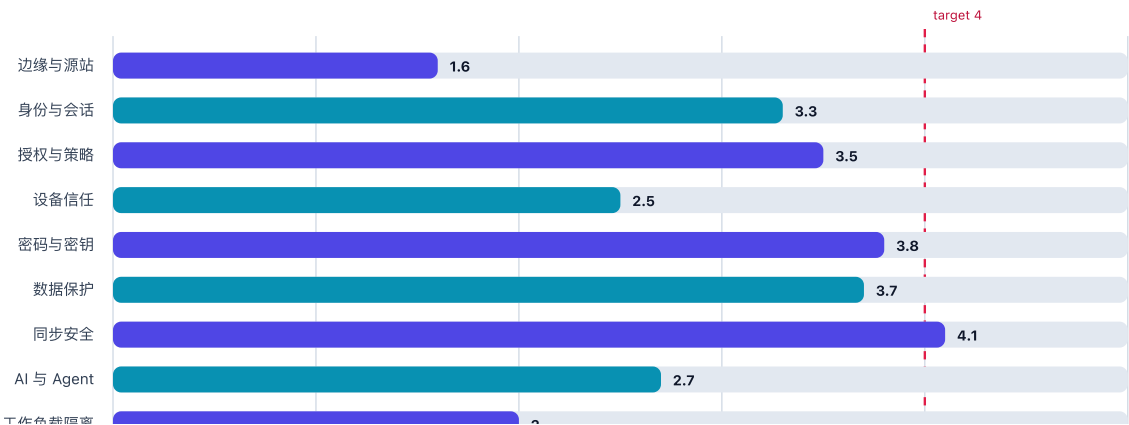
Architecture reading

当前架构已具备清晰的控制面/数据面/通知面分离，但 V1.0 把目标扩大为‘产品 + 云平台 + 安全运营 + 组织治理’。因此最小侵入路线不是把 Athena 改成一套庞大安全总线，而是：统一所有入口的 principal 校验；让数据分类驱动既有 Repository/Outbox/对象层；将外部 WAF、KMS、SIEM、DR 作为可替换平台能力接入。

2. Maturity & Control Coverage

V1.0 target maturity by security domain

0 = missing; 3 = locally implemented; 5 = continuously enforced and independently proven.



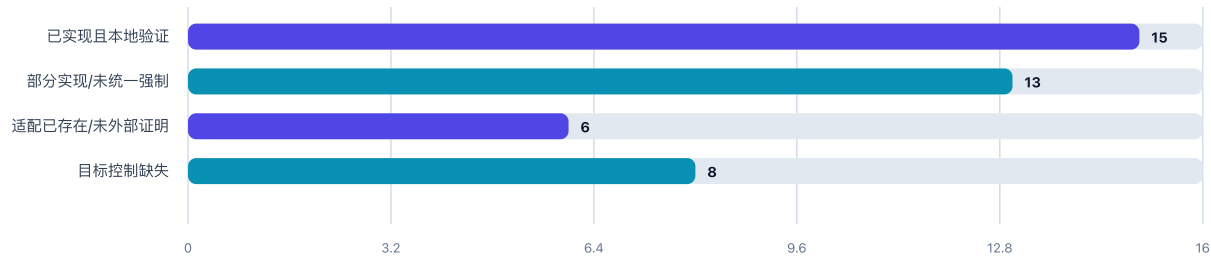
V1.0 target maturity by security domain

Source: Athena V1.0 security gap evidence snapshot
Tables: workspace_chats, sync_nodes

Domain	Maturity
边缘与源站	1.6
身份与会话	3.3
授权与策略	3.5
设备信任	2.5
密码与密钥	3.8
数据保护	3.7
同步安全	4.1
AI 与 Agent	2.7
工作负载隔离	2
供应链	3.2
审计与 SecOps	3
备份与灾备	1.8

Control implementation status

Only controls with code or runtime evidence are counted as implemented.



V1.0 Control Coverage Matrix

Each printable audit row contains the current evidence, residual gap and minimum-intrusion action.

Passkey / OPAQUE / Session V2	CURRENT — Passkey 与 OPAQUE 路径、Auth DB session、吊销与 tokenVersion 已实现；REST middleware 权威校验。 GAP — Broadcast、Agent、Crypto WebSocket 未复用同一权威校验；query token 增加泄露面。 ACTION — P0：统一 WS auth adapter，短期 ticket，撤销后主动 close。
RBAC + 资源级关系授权	CURRENT — Workspace、Thread、Chat、文件、Agent invocation 均有 owner/resource 约束；338 路由审计 0 finding。 GAP — 尚无统一 PE/PA/PEP 与设备/风险/数据等级上下文。 ACTION — P1：保留领域查询，抽出统一决策接口与 reason code。
设备签名与反重放	CURRENT — P-256、nonce、timestamp、body hash、高风险请求验证与设备撤销能力存在。 GAP — 开发环境仍为 warn-only；WebSocket 低风险控制消息可降级；iOS 私钥可导出后写 Keychain。 ACTION — P0/P1：生产强制；iOS 迁移 Secure Enclave 非导出密钥。
传输安全	CURRENT — TLS/HSTS、生产 HTTPS fail-closed、CORS allowlist、SSE 安全头、TLS 1.2+ 测试。 GAP — TLS 1.3 非强制；外部 WAF/CDN/DDoS/DNSSEC 与源站 mTLS 不在仓库证据内。 ACTION — P1：部署基线与证据采集；兼容期优先 TLS 1.3。
请求入口与滥用防护	CURRENT — 按路由 body limits、登录持久限流、Passkey 限流、Collector 资源上限。 GAP — 没有统一 API Gateway schema/risk quota；/ready 暴露内部 worker 与审计细节。 ACTION — P0：拆分 public liveness 与 authenticated diagnostics。
静态数据加密	CURRENT — AES-256-GCM/HKDF、DEK 信封、Chat 1,038/1,038、文档/向量/缓存全覆盖，链断裂 0。 GAP — system_settings 依赖字段判定；缺统一 S0-S4 数据目录与保留/驻留策略。 ACTION — P1：分类 registry 驱动加密、日志、导出与保留。

密钥托管与轮换	CURRENT — Key Custody provider、keyId/keyring、pending/activate/retire、secret-file、冲突 fail-closed。 GAP — 当前根密钥仍是 env/file；KMS/Vault/HSM、双人审批与硬件根未落地。 ACTION — P1/P2：staging 接 KMS/Vault；高价值租户再评估 HSM。
iOS 设备密钥	CURRENT — Keychain ThisDeviceOnly 与 userPresence 已使用。 GAP — RequestSigningCenter 生成 CryptoKit 私钥后持久化 rawRepresentation，未使用 Secure Enclave。 ACTION — P1：版本化注册新公钥，双钥迁移，旧钥定期退役。
Sync V2 一致性与完整性	CURRENT — 263 节点、186 投影；version/hash/outbox/cursor/receipt/reconcile；0 hash/权限/正文冲突。 GAP — 当前环境 enabled=false；最大 cursor lag 696；需要授权多设备 E2E 与灰度证明。 ACTION — P1：deterministic cohort 与 SLO 门禁，不扩大状态树边界。
Chat 与审计完整性	CURRENT — Chat Hash Chain；安全账本 Hash Chain + Ed25519 checkpoint，13 entries/4 checkpoints 均有效。 GAP — 外部不可变归档默认关闭；未接 SIEM/WORM，ready 暴露 head hash。 ACTION — P1：对象锁/WORM、导出重试、仅内部诊断展示链状态。
Collector SSRF 与解析隔离	CURRENT — 私网/元数据阻断、重定向重校验、压缩包/大小/超时/并发保护、非 root/read-only。 GAP — 开发态跳过 integrity；absolutePath 公开 DTO；可读取进程可见任意文件。 ACTION — P0：opaque staging handle；absolutePath 仅进程内私有调用。
Collector 爆炸半径	CURRENT — cap_drop ALL、no-new-privileges、tmpfs、任务并发限制。 GAP — 容器挂载完整 server/storage 且继承 .env；缺出站网络默认拒绝与独立服务身份。 ACTION — P0：最小目录、独立 env、network policy、只读输入/只写输出。

Agent 与插件能力	CURRENT — capability manifest/broker、短期签名凭据、工具审批、超时、路径与网络约束、容器策略。 GAP — 控制主要覆盖 scheduled/MCP；内建工具未全部进入统一 broker；高风险 worker 未生产隔离证明。 ACTION — P1：统一 tool execution context 与 capability enforcement。
RAG / Memory 安全	CURRENT — save_memory 需要显式意图与用户审批；账户记忆有独立模型。 GAP — rag-memory.store 可直接写 workspace vector；检索结果未标记 untrusted/provenance，存在持久化污染。 ACTION — P0：候选态、来源签名、taint envelope、敏感/指令过滤。
NATS / 内部服务通信	CURRENT — JetStream adapter、durable consumer、eventId 去重、subject scope HMAC、lag/health/drain。 GAP — 客户端未配置 TLS/mTLS/nkey；当前仅 adapter/fault-test，未多实例实网。 ACTION — P1：生产 profile 强制 tls://、证书轮换、subject ACL、workload identity。
数据库与对象存储	CURRENT — SQLite 当前权威；PostgreSQL schema/CDC/cutover 与 S3/MinIO provider 已准备。 GAP — 没有外部多节点、池耗尽、网络分区和反向影子七日证明。 ACTION — P1：隔离 staging 执行故障矩阵后再切权威。
供应链	CURRENT — Actions 固定 SHA、远程脚本校验、SBOM/provenance/VEX、reachable Critical=0 门禁。 GAP — raw High：server 114、collector 40、frontend 11；未见统一镜像签名/admission policy。 ACTION — P1：Reachability owner/expiry；Cosign + deploy admission。
可观测与自愈	CURRENT — Runtime Coordinator、outbox DLQ/lease、receipt sweeper、reconcile、OTel/Prometheus adapters。 GAP — 开发进程内指标不能证明长期 p95/错误预算；外部 telemetry/SIEM 未部署。 ACTION — P1：staging collector + trace correlation + SLO burn alerts。

备份与灾备	CURRENT — 迁移/修复前本地备份、校验、可恢复脚本、内容对象不可变键。 GAP — 无独立账户/跨区域 immutable backup、RPO/RTO 证据、完整恢复演练。 ACTION — P2: 3-2-1、隔离密钥、季度 restore drill、审计证据。
高权限运维	CURRENT — 角色层级、会话吊销、账户删除工作流、dry-run/--execute 安全语义。 GAP — 无 JIT/PAM、break-glass 审批、双人控制和统一 incident console。 ACTION — P2: 短期管理员授权、双人审批、统一 kill switches。

3. Findings — Exploitable Paths First, Maturity Gaps Second

四个 High 都可以在不改变用户业务语义的前提下修复：会话与设备仍使用现有 Auth DB；Collector 仍支持现有上传和解析，只把路径能力收回服务端；Memory 仍可保存，只先进入候选态。KMS、WAF、SIEM 等未外部证明项属于发布与成熟度门槛，不应误报为当前本机漏洞。

Confirmed Findings & Assurance Gaps

Confirmed defects are separated from deployment and operating-model assurance gaps.

ATH-V1-001 · High · 已确认	PATH — 撤销/窃取 JWT → Broadcast/Agent/Crypto WS → decodeJWT/resource lookup，但不查 AuthSession.validate。 IMPACT — 会话吊销不能保证立即终止长连接；query token 可能进入代理、历史或日志。 ACTION — P0: 权威 WS principal adapter + 60–120 秒 ticket + 周期复核 + revoke-close。
ATH-V1-002 · High · 已确认	PATH — 开发 Collector /parse 接收 options.absolutePath；完整性校验在 development 跳过。 IMPACT — 本机/开发环境中，调用者可请求解析 Collector OS 权限可读文件。 ACTION — P0: 删除公开字段；API 签发 opaque file handle；loopback bind 和开发签名。
ATH-V1-003 · High · 已确认	PATH — Collector 容器继承 .env，并读写挂载完整 server/storage。 IMPACT — 解析器 RCE、依赖漏洞或恶意文档可扩大到应用数据与 Secret。 ACTION — P0: 独立身份与 env；最小挂载；默认无网络；一次性任务目录。

ATH-V1-004 · High · 已确认 PATH — rag-memory.store 直接写 workspace vector；search 以 Additional context 原样返回。
IMPACT — 间接 Prompt Injection 可转为长期知识污染并影响后续 Agent 决策。
ACTION — P0: memory candidate + provenance/taint + approval + recall-time untrusted wrapper。

ATH-V1-005 · Medium · 已确认 PATH — 公共 /ready 返回 hostname/pid 关联 workerId、计数器、审计 chainId/head hash。
IMPACT — 扩大侦察信息和内部运行拓扑暴露；高敏诊断不应匿名公开。
ACTION — P0: /live 极简；/ready 仅状态；/internal/diagnostics 强认证。

ATH-V1-006 · Medium · 已确认 PATH — iOS P-256 私钥 rawRepresentation 写入 Keychain，而非 Secure Enclave 非导出密钥。
IMPACT — Keychain 提供良好静态保护，但未达到报告要求的硬件不可导出。
ACTION — P1: Secure Enclave key agreement/signing，保留设备兼容降级策略。

ATH-V1-007 · Medium · 已确认 PATH — 服务端凭据主路径仍使用 bcryptjs；报告目标为 Argon2id + HSM pepper。
IMPACT — 不构成直接绕过，但抗离线破解与密钥分离未达到金融级目标。
ACTION — P1: 登录时渐迁 Argon2id；pepper 仅在 KMS/HSM 阶段启用。

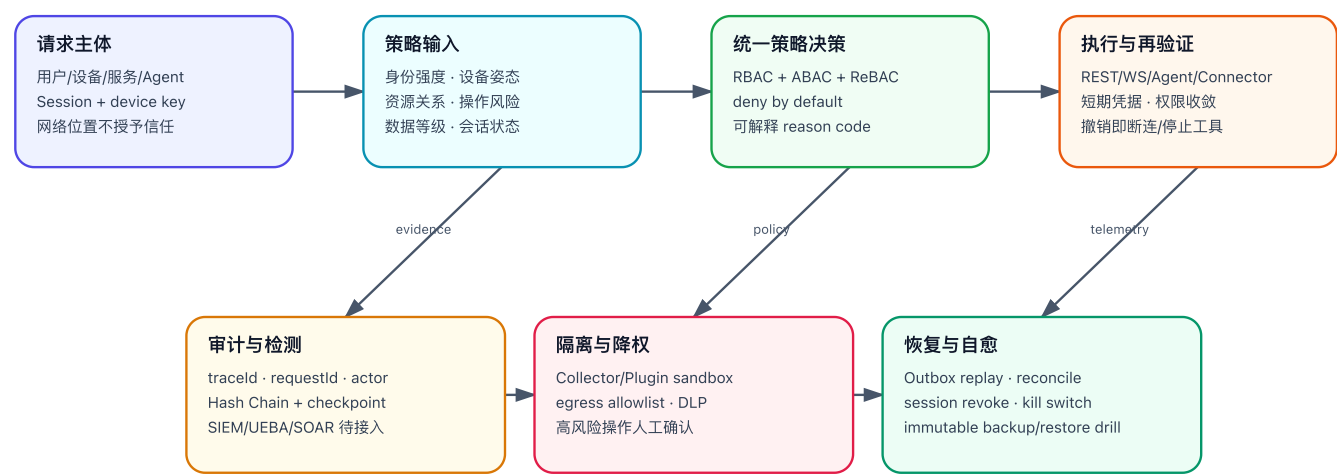
ATH-V1-008 · Medium · 条件性 PATH — 开发 security policy 为 requestSigningWarnOnly=true、deviceRequired=false、strictReady=false。
IMPACT — 若错误带入生产会形成安全降级；当前只能证明开发态配置。
ACTION — P0 发布门禁：production profile fail-closed，禁止 warn-only/开发 bypass。

ATH-V1-009 · Medium · 发布前 PATH — NATS adapter 支持 user/pass/token，但 connect 未配置 TLS/CA/client cert/nkey。
IMPACT — 启用跨实例后，内部事件的服务身份和链路机密性不足。
ACTION — P1: 在 ATHENA_BROADCAST_TRANSPORT=nats 时强制 tls:// 与 ACL。

ATH-V1-010 · Medium · 成熟度	PATH — 安全账本签名有效；immutable archive 默认 disabled，未见生产 SIEM/SOAR 证据。 IMPACT — 本机证据链强，但独立留存、集中检测与响应闭环不足。 ACTION — P1: WORM/object lock + SIEM + retry/alert + incident runbook。
ATH-V1-011 · Medium · 成熟度	PATH — DataAccessCenter 有 public/internal/user/sensitive/secret/ephemeral 分类，但非统一 S0-S4 策略。 IMPACT — 分类尚未统一驱动 DLP、驻留、导出、保留和水印。 ACTION — P1: 建立可机读数据目录与 policy-as-code；逐域映射，不批量重写。
ATH-V1-012 · Medium · 成熟度	PATH — Key provider 当前 env-file/secret-file/environment；external KMS/Vault 标为 reserved。 IMPACT — 密钥材料和应用工作负载仍在同一管理域，无法证明硬件根与职责分离。 ACTION — P1/P2: 先 Vault/KMS staging，再按客户需求升级 HSM/双人恢复。
ATH-V1-013 · Medium · 证据缺口	PATH — 应用内 TLS/CORS/header 存在；WAF/CDN/DDoS/DNSSEC/源站 mTLS 不在仓库与本机范围。 IMPACT — 不能对边缘抗压、Bot、源站隐藏做金融级声明。 ACTION — P1: 把 edge 配置、健康与演练证据纳入 release evidence bundle。
ATH-V1-014 · Medium · 证据缺口	PATH — 有本地备份与修复脚本，但无跨账户/跨区域恢复演练证据。 IMPACT — 勒索、区域故障、密钥损坏下的 RPO/RTO 不可证明。 ACTION — P2: 独立密钥域、不可变备份、季度 restore test。

4. Recommended Zero Trust Enforcement Loop

推荐 Zero Trust 闭环：每次请求、每条长连接、每次工具调用都重新证明



Design rule

Zero Trust 的实施单元不是一个新‘安全中心’数据库，而是一个稳定的 AuthorizationContext 和少量 enforcement adapters：REST middleware、WebSocket handshake/refresh、Agent tool invocation、Connector egress、Data export。领域 Repository 继续决定业务关系；策略层只做组合决策、记录 reason code，并在撤销或风险变化时终止能力。

5. P0 Optimization Plan — 0 to 14 Days

P0 Closed-loop Optimization Plan

Every change includes an acceptance gate and rollback boundary; no key rotation is required.

1. 长连接身份统一	IMPLEMENT — 建立 authoritativeRealtimePrincipal(request)：Session V2、authUser、clientId、tokenVersion、设备状态统一校验；禁止新增 query JWT；引入一次性短期 WS ticket。 GATE — 退出/封禁/设备吊销 ≤5 秒断开；旧客户端双读迁移；REST/WS principal 一致。 ROLLBACK — 短期保留 Bearer 双读开关；ticket 失败退回旧握手但仍执行 Session V2。
2. Collector 文件句柄	IMPLEMENT — 外部 DTO 只接受 uploadId/objectRef；absolutePath 仅内部不可序列化调用；每次 realpath 限制到 staging root。 GATE — 任意绝对路径、symlink、目录穿越全部拒绝；合法上传兼容；无 Secret/路径出现在响应。 ROLLBACK — 旧字段仅允许 loopback + 内部签名 + 7 日 telemetry，随后移除。
3. Collector 隔离	IMPLEMENT — 拆分 Collector env；移除整库挂载；输入只读、输出只写；network none 默认；必要域名经 egress proxy。 GATE — 恶意文档无法读取 Auth DB/.env/主库；容器 RCE 影响限制在一次性目录；功能格式回归通过。 ROLLBACK — 按格式 allowlist 回退到受限 legacy worker，不回退为全存储挂载。

4. RAG/Memory 污染防治	IMPLEMENT — rag-memory.store 写 candidate；记录来源、actor、thread、hash、信任级别；审批后进入可检索索引；检索内容包装为 untrusted evidence。 GATE — 间接指令不能直接写长期向量；用户可查看/拒绝/删除；召回不会覆盖 system/tool policy。 ROLLBACK — 候选功能关闭时禁用 store，只保留 search；不丢弃现有向量。
5. 生产策略配置门禁	IMPLEMENT — 生产启动校验 request signing/device required、strict readiness、CORS allowlist、HTTPS、dev bypass off；失败即 not-ready。 GATE — 错误生产配置无法启动；开发体验不变；密钥内容与时间戳不修改。 ROLLBACK — 按单控制 feature flag 回滚，但保持显式告警与审计，不提供静默 global bypass。
6. 健康与诊断分层	IMPLEMENT — `/live` 只返回存活；`/ready` 只返回 ready/reasonCode；计数、worker、链状态移到强认证 internal diagnostics。 GATE — 匿名响应不包含 pid/hostname/hash/内部计数；监控探针继续 200/503；运维诊断信息不丢失。 ROLLBACK — 保留内部 legacy payload 端点，不恢复公共详细响应。

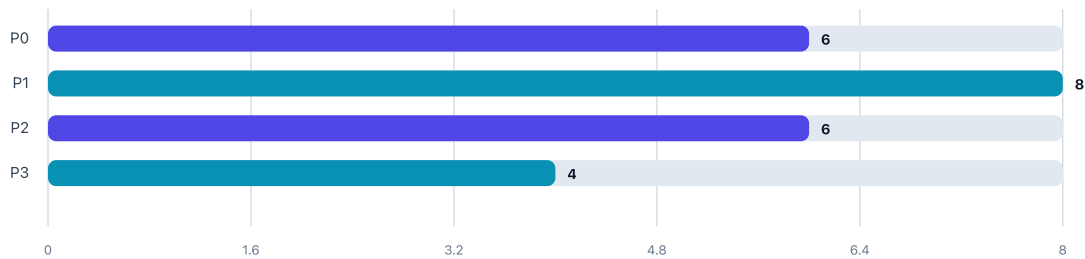
Required sequence

- 1. 先引入共享 WS principal adapter 和只读 telemetry，验证新旧 principal 一致。
- 2. 再签发短期 WS ticket，并保留旧 Bearer 双读；确认 revoke-close 后禁止 query JWT。
- 3. Collector 先影子生成 opaque handle，再切读路径；隔离挂载与 env 最后启用。
- 4. Memory 先记录候选而不改变 search；候选 UI/审批可用后关闭 direct store。
- 5. 生产门禁和健康端点分层可独立上线，不依赖数据迁移。

6. P1/P2/P3 Evolution Roadmap

Recommended optimization backlog by priority

P0 closes exploitable or fail-open paths; later phases establish enterprise proof.



Security Evolution Roadmap

Reduce exploitability first, then establish enterprise operating proof.

P0 · 0–14 天	SCOPE — WS Session、Collector 句柄/隔离、RAG taint、生产门禁、健康端点 VALUE — 关闭 4 个已确认 High 与 1 个信息泄露面；不改业务数据模型。 COST/RISK — 中等；主要风险是旧客户端握手和文档导入兼容。
P1 · 15–45 天	SCOPE — 统一 policy adapter、Secure Enclave、Argon2id 渐迁、NATS TLS、数据目录 VALUE — 让身份、设备、关系、风险、数据等级进入统一决策；为多实例上线建立安全前提。 COST/RISK — 中高；必须按 adapter 渐迁，禁止一次性替换领域授权。
P1 · 30–60 天	SCOPE — KMS/Vault staging、WORM audit、SIEM/OTel、SBOM 签名与 admission VALUE — 从本地可验证升级为跨系统可证明，建立检测与供应链证据链。 COST/RISK — 中高；依赖外部基础设施与轮换/故障演练。
P2 · 60–120 天	SCOPE — Service identity/mTLS、egress+DLP、JIT/PAM、统一 incident console VALUE — 缩小横向移动和数据外泄半径，支撑企业管理员与高权限 Agent。 COST/RISK — 高；需要平台工程和安全运营共同所有。
P2 · 90–180 天	SCOPE — 跨账户/跨区域 immutable backup、RPO/RTO、完整恢复演练 VALUE — 把‘有备份’提升为‘可恢复’，覆盖勒索、区域故障与密钥事故。 COST/RISK — 高；需要真实云资源与演练窗口。
P3 · 6–18 月	SCOPE — HSM root、客户管理密钥、机密空间、阈值/分片恢复、PQ agility VALUE — 服务高价值企业和监管场景；按需求启用，不强行覆盖搜索/AI 主链。 COST/RISK — 很高；只有明确合规和客户收益时引入。

7. Cryptography & Confidentiality Decisions

- **立即保留：** AES-256-GCM + HKDF + per-object DEK；Chat/Audit Hash Chain；Ed25519 审计 checkpoint；Passkey/OPAQUE；P-256 设备签名。
- **下一阶段接入：** KMS/Vault provider、Secure Enclave、NATS mTLS、对象锁/WORM；先 staging 轮换和故障演练，不修改现有密钥。
- **按需求引入：** HSM root、客户管理密钥、Threshold Signature、Shamir Secret Sharing，仅用于高价值密钥恢复或多方审批。
- **暂不普遍引入：** Signal/MLS E2EE 会与服务端搜索、RAG、Agent 推理和合规检索冲突；只适合未来明确的‘机密空间’，不能覆盖普通 Workspace。
- **不作为安全替代品：** Merkle Tree/CRDT/Event Stream 解决对账、协作和历史，不替代身份、授权、加密或审计。

8. AI, Agent, MCP & Memory Security

Athena 已经比普通 Agent 平台更成熟：工具审批、能力清单、短期凭据、容器约束、文件路径和网络域限制、成本/超时治理都存在。但控制覆盖不均衡：scheduled/MCP 路径较强，内建工具和 rag-memory 没有全部穿过同一 capability broker。建议以 [OWASP AISVS 1.0](#) Level 2 为生产目标，优先覆盖 Memory/Vector、Agentic Action、MCP、Monitoring 四章。

9. Data Classification, DLP & Privacy

DataAccessCenter 已有 public/internal/user/sensitive/secret/ephemeral 分类，这是重要基础，并非从零开始。下一步应把它升级为可机读目录：owner、legal basis、residency、retention、encryption profile、export policy、log policy、AI usage policy。用户报告中的 S0–S4 可以作为展示与审计等级，但内部仍可保留现有语义枚举，通过映射层避免大规模 Repository 重写。DLP、水印、导出审批应只针对 S3/S4 和高风险动作，避免给普通聊天与设置带来全局性能回退。

10. SecOps, Incident Response & Self-healing

现有 Runtime Coordinator、Outbox DLQ/lease、receipt sweeper、auth-session reconcile、Hash 校验和 immutable object key 已形成自愈基础。企业级闭环还需要统一 incident control plane：租户隔离、Connector all-off、Agent high-risk tools off、export freeze、read-only mode、session mass revoke、key disable。所有动作必须进入签名审计链，并能通过 SIEM/SOAR 触发，但不得让 SIEM 成为业务请求的同步依赖。

11. Testing, Release Gates & Rollback

Verification, Fault Injection & Release Gates

A control is complete only when failure semantics and operational evidence are verified.

Identity/WS	TEST — 创建 session → WS 连接 → revoke/device revoke/ban/logout → 观察断连与后续握手。 GATE — 全部路径 ≤5 秒生效；不得仅等 JWT 过期。 EVIDENCE — 自动化 E2E + audit event + socket close code。
Collector path	TEST — absolute path、symlink、hardlink、目录穿越、文件替换竞态、超大文件。 GATE — 仅 opaque staging handle 可成功；路径不出现在日志/响应。 EVIDENCE — fault injection + container mount inventory。
Collector sandbox	TEST — 恶意解析器尝试读取 /app/server/.env、Auth DB、网络元数据与任意域名。 GATE — 全部 fail-closed；合法格式回归不超过既有 p95 10%。 EVIDENCE — container integration + egress log。

RAG memory	TEST — 网页/PDF 中嵌入保存指令、越权工具指令、伪造系统提示。 GATE — 只生成候选或拒绝；未经用户确认不进入长期索引。 EVIDENCE — OWASP AISVS L2 adversarial suite。
Sync	TEST — 重复/乱序/丢失 WS/SSE/Push、缓存写失败、Hash 不同、权限撤销。 GATE — cursor/ACK 不提前；Hash mismatch <0.01%；full reconcile <1%。 EVIDENCE — Web+iOS 授权多设备 E2E。
Crypto	TEST — key provider 断连、旧 key 解密、轮换中断、对象写成功 DB 失败。 GATE — 不产生孤儿引用或不可恢复密文；不输出 key material。 EVIDENCE — staging KMS/Vault rotation drill。

NATS/mTLS	TEST — 无证书、错误 subject、证书轮换、网络分区、consumer redelivery。 GATE — 未授权连接拒绝；Outbox 可补拉；Gateway not-ready。 EVIDENCE — distributed staging fault matrix。
Audit/SIEM	TEST — 篡改 ledger、删除 archive、archive provider 故障、告警链路中断。 GATE — 验证失败可见；导出重试；WORM 对象不可覆盖；SOC 收到告警。 EVIDENCE — signed checkpoint + object lock + alert receipt。
Supply chain	TEST — 依赖 Critical、未固定 Action、无 provenance、未签名镜像、过期 High waiver。 GATE — 发布全部阻断；reachable Critical=0；High 有 owner/expiry。 EVIDENCE — CI policy report + signature verification。

DR

TEST — 在隔离账户从数据库、对象、向量、Auth、密钥与 Outbox 恢复。
GATE — 满足正式 RPO/RTO；权限/Session/Hash Chain/Sync 全部复核。
EVIDENCE — 季度 restore report 与 CTO/Security sign-off。

12. Performance, Cost & Complexity Impact

- WS 权威 Session 校验可复用 5 秒正向缓存；握手增加一次 Auth DB 读取，稳定连接只做周期轻量复核，预计普通 REST 无回退。
- Collector opaque handle 消除任意路径分支，隔离容器会增加冷启动与文件复制成本；通过 worker 池、内容对象引用与流式处理控制在 10% p95 门槛内。
- Memory 候选态增加一次元数据写和审批交互，但避免污染导致的长期召回成本与安全事故。
- 数据分类映射应在 Repository/Outbox 边界计算，不扫描全文，不进入每次 Token 流。
- KMS 只封装/解封 DEK，不对每个字节远程加密；热点 DEK 使用短期内存缓存并受进程生命周期约束。
- SIEM、WORM、OTel 采用异步可靠投递；安全审计本地事务失败必须 fail-closed，高容量遥测失败则降级并告警。

13. Standards & Assurance Mapping

Standards Mapping

Standards guide verification; this report does not claim certification or compliance.

NIST SP 800-207 / 207A	PURPOSE — Zero Trust：不因网络位置授信；用户、设备与工作负载身份都需要策略决策与执行。 ATHENA — 资源级 AuthZ、Session/设备签名已有；统一 PE/PA/PEP、service identity/mTLS 待补。
OWASP ASVS 5.0	PURPOSE — 应用安全可验证需求基线，用于身份、会话、输入、文件、API、日志与配置门禁。 ATHENA — 现有 route/security audit 可转为 ASVS requirement ID 的机器可读 control ledger。
OWASP AISVS 1.0	PURPOSE — AI 系统 L1-L3 验证，覆盖 memory/vector、Agent action、MCP、监控与对抗鲁棒性。 ATHENA — 建议生产面向敏感数据达到 L2；Memory/Agent/Connector 是首个缺口域。

NIST CSF 2.0	PURPOSE — Govern、Identify、Protect、Detect、Respond、Recover 的运营闭环。 ATHENA — Protect 较强；Govern/Detect/Respond/Recover 需要 SIEM、incident console 与 DR 演练。
SLSA 1.2	PURPOSE — Source/Build provenance、逐级保证、artifact verification。 ATHENA — SBOM/provenance 与 pinned Actions 已有；镜像签名、admission、source control policy 需闭环。

Primary references

[NIST SP 800-207 Zero Trust Architecture](#) · [OWASP ASVS 5.0](#) · [OWASP AISVS 1.0](#) · [NIST CSF 2.0](#) · [SLSA 1.2](#)

14. Limitations, Uncertainty & Robustness

- 本轮未使用用户凭据，浏览器动态审计只覆盖匿名页面；授权多设备 E2E 是后续必要证据。
- 本机没有获准的外部 PostgreSQL/NATS/S3/KMS/SIEM、WAF 或跨区域环境，因此只能评估代码边界与本地故障语义。
- 开发环境策略为 warn-only 不能推断生产必然同样配置；报告将其作为发布门禁，而非已暴露生产漏洞。
- 依赖 raw High 反映 package tree，不等于 165 个可利用漏洞；当前门禁证明 reachable Critical=0，但每个 High 仍需 owner、mitigation 和 expiry。
- 架构评分包含专家判断，不是渗透测试、合规认证或金融监管批准。

15. Recommended Next Steps

1. 把本报告 6 个 P0 workstream 建成单独 feature flags, 先 shadow/telemetry, 再双读、强制、移除旧路径。
2. 建立机器可读 security-control-ledger.json, 每个控制关联 owner、code path、test、runtime evidence、exception、expiry。
3. 在 Docker-capable staging 完成 NATS mTLS、Collector sandbox、KMS/Vault、WORM audit 与 OTel/SIEM 演练。
4. 建立 Web+iOS/Desktop 授权多设备安全 E2E, 覆盖 session revoke、permission revoke、offline replay、account switch 和 push loss。
5. P0 全部关闭后再做外部边缘、JIT/PAM、DLP 和跨区域 DR; 不为了贴合报告名词强行引入 HSM、Threshold 或全面 E2EE。

16. Further Questions for the Security Committee

- Athena 首个需要金融级保护的资产是用户私密记忆、企业知识库、Agent 操作权限还是交易/账务?
- 企业客户是否要求 BYOK/HYOK、数据驻留、WORM、双人审批或特定 RPO/RTO?
- 哪些 Agent 工具必须具备网络访问, 哪些可以完全无网络?
- ‘机密空间’是否允许牺牲全文搜索、RAG 和服务端 Agent 推理以换取 E2EE?
- 第一阶段安全运营由内部团队还是外部 MSSP/SOC 承担? 这决定 SIEM/SOAR 与 on-call 设计。

Final Assessment

当前产品安全姿态：7.4/10。V1.0 金融级完整蓝图完成度：61.0%。

Athena 的密码、数据完整性、状态同步和资源授权基础已经领先于同阶段 AI 产品；真正的短板不是缺少更多密码学名词，而是四条高风险路径尚未统一执行已有控制，以及外部分布式与安全运营能力尚未获得生产证据。按本报告 P0→P1→P2 顺序推进，可以在保留现有 REST、SSE、WebSocket、Sync V2、领域 Repository 与客户端缓存语义的前提下，逐步达到大型互联网平台的可审计、可回滚、可恢复安全架构。

Source: Athena V1.0 security gap evidence snapshot

Tables: workspace_chats, sync_nodes